

CompTIA CySA+ Glossary

Estimated time needed: 20 minutes

Welcome to your study glossary for CompTIA CySA+.

A vital part of preparing for your testing experience is knowledge of the many technical terms you will encounter during testing. You also need to know more than the term's definition, you'll need to be able to apply that terminology to relevant cybersecurity business needs and challenges, with split-second precision. This glossary can help.

Getting Started

The CompTIA CySA+ exam consists of four domains. You'll find specific terms associated with each domain. Related exam questions apply those terms within questions in the context of planning or solving a related cybersecurity situation.

This glossary categorizes relevant CySA+ terms based on their exam domains and includes a relevant example with each term.

What you will learn

After completing this reading, you will be able to:

- Define relevant CySA+ terms associated with each domain.
- Describe a relevant CySA+ business use applicable to each term.

Let's get started!

Domain 1: Security Operations

Term	Definition	Example
Advanced Persistent Threat (APT)	APT is a type of cyber-attack where a threat actor gains unauthorized access to a network and remains undetected for an extended period.	An example of an APT is when a state-sponsored group infiltrates a government agency's network and remains undetected for months while gathering sensitive information.
Closed source intelligence	Closed source intelligence collects and analyzes classified or restricted information primarily used by the government.	An example of closed source intelligence is when a government agency gathers sensitive information on potential threats from foreign adversaries to safeguard national security.
Cloud Access Security Broker (CASB)	A CASB is a solution that helps organizations secure their data and applications in the cloud. It acts as a gatekeeper between users and the cloud, providing visibility, control, and protection for cloud-based services.	An example of CASB is when an organization employs a third-party service to monitor and manage user access to its cloud-based applications, ensuring security policies are enforced and sensitive data is protected.
Data Loss Prevention (DLP)	DLP is a security strategy that helps organizations prevent the unauthorized disclosure of sensitive data.	An example of DLP is when an organization uses software to scan outgoing emails for sensitive information, like credit card or social security numbers, and automatically blocks or encrypts the content to prevent it from leaving the company network.
Domain-Based Message Authentication, Reporting, and Conformance (DMARC)	DMARC is an email authentication protocol that helps prevent email spoofing and phishing attacks by verifying the sender's identity and ensuring that emails are delivered to the intended recipient.	An example of DMARC is when a company configures DMARC policies to align with their DKIM (domain keys identifiable mail) and SPF (sender policy framework) settings, preventing the unauthorized use of their domain to send fraudulent emails.
Domain Keys Identifiable Mail (DKIM)	DKIM is a security method that allows email senders to digitally sign their emails. This will enable recipients to verify the sender's authenticity and detect tampering or forgery.	An example of DKIM is when an organization signs all outgoing emails from its domain, ensuring recipients that an authorized sender sent the email and that it has not been altered during transit.
Endpoint Detection and Response (EDR)	A security solution that monitors endpoints, like computers and mobile devices, to detect and respond to suspicious activity and mitigate potential threats.	An example of EDR is when a company deploys software on employee computers to monitor for unusual activities, such as attempts to access unauthorized files or changes to system settings.
Federation	Federation links multiple identity management systems, enabling secure access to various applications and services with a single set of credentials.	An example of federation is when a user from one organization can access an application hosted by another organization using their existing login credentials without creating a new account with the hosting organization.
Hacktivists	Hacktivists are individuals or groups who use hacking techniques to promote a social or political cause.	An example of hacktivism is when a group hacks into a company's website and defaces it to protest its unethical business practices.
Hashing	Hashing is a mathematical process that transforms data of any size into a fixed-size output called a hash value.	An example of hashing is when a website stores user passwords in hashed form so that hackers cannot obtain the actual passwords even if the database is breached.
Honeypot	A decoy system or network is created to lure attackers and collect information on their tactics and techniques.	An example of a honeypot is when a company intentionally deploys a decoy server with vulnerable software.

Term	Definition	Example
Indicators of Compromise (IoC)	Artifacts or patterns that suggest a possible or ongoing security breach or malicious activity within a system or network.	An example of an indicator of compromise is when a security analyst detects unusual network traffic originating from a specific IP address, indicating a potential malware infection or unauthorized access.
Insider threat	An insider threat is a security risk posed by individuals within an organization.	An example of an insider threat is when an employee with authorized access to confidential data deliberately leaks it to competitors for financial gain.
Intelligence gathering	Collecting information about a target system or organization to identify potential attack vectors and vulnerabilities.	An example of intelligence gathering is when a hacker researches publicly available information about a company's network infrastructure and employees to prepare for a targeted attack.
Internal network pen test	A test that simulates the behavior of malicious insiders or individuals with stolen credentials seeking to exploit vulnerabilities within the network.	An example of an internal network penetration test is when a company hires ethical hackers to try accessing sensitive information using stolen credentials or insider knowledge.
Log analysis	Log analysis involves collecting and analyzing log data from various systems, such as network devices, servers, and applications.	An example of log analysis is when a security team examines web server logs to identify any attempted cyber-attacks on the website.
Multifactor Authentication (MFA)	MFA is an authentication method that requires users to provide at least two forms of verification to access a system or application.	An example of MFA is when a user is required to enter a unique code sent to their phone, along with their password, to log into an online account.
Nation-state actor	A nation-state actor is a threat entity sponsored or controlled by a government, typically engaged in gathering intelligence or disrupting the operations of other countries.	An example of a nation-state actor is when a foreign government conducts cyber-attacks to steal sensitive information from another country's government or organizations.
Open-source intelligence	Open-source intelligence involves collecting and analyzing publicly available data from various sources to gain insights or support decision-making.	An example of open-source intelligence is when an organization monitors social media platforms to assess customer sentiment and track industry trends.
Operational threat intelligence	Intelligence related to operational threats focuses on current and emerging risks that could impact an organization's operations.	An example of operational threat intelligence is when an organization monitors cyber-attacks targeting their specific industry or technology to prepare for and defend against potential threats proactively.
Organized crime	Organized crime refers to groups of individuals coordinating criminal activities, such as fraud and extortion, for financial profit.	An example of organized cybercrime is when hackers breach a company's network, steal sensitive customer data, and sell it in the black market for financial gain.
Packet capture	Packet capture, also known as packet sniffing, intercepts and records network traffic for analysis or troubleshooting purposes.	An example of packet capture is when a network administrator uses software to monitor and record all incoming and outgoing network traffic to identify any suspicious activity or potential vulnerabilities.
Personally Identifiable Information (PII)	PII refers to any data that can be used to identify an individual, including their name, date of birth, social security number, or address. Privacy laws and regulations typically safeguard this information.	An example of PII is when customers provide their full name and credit card details to purchase online.
Privileged Access Management (PAM)	PAM is a security system that controls and monitors access to privileged accounts, such as administrator or root accounts.	An example of PAM is when an IT administrator requests temporary access to a system using their standard login credentials. This is followed by additional verification steps, such as multifactor authentication, before elevated privileges are granted.
Public Key Infrastructure (PKI)	Public key infrastructure (PKI) is a system of hardware, software, and policies that manages digital certificates and public-private key pairs.	An example of PKI is when a website uses an SSL certificate to create a secure connection between the user's browser and the server, ensuring that all data transmitted between them is encrypted and protected from eavesdropping.
Risk management	Identifying, assessing, and prioritizing potential risks to an organization's assets and implementing controls to mitigate those risks.	An example of risk management is when a business analyzes potential threats and vulnerabilities to its network and implements security measures to address them.
Sandboxing	Sandboxing is a security technique that isolates applications or processes from the rest of the system to prevent potential harm.	An example of sandboxing is opening an email attachment in a virtual environment, separate from the primary operating system, to ensure it does not contain malware before being downloaded into the user's computer.
Script kiddie	A script kiddie is a person who uses existing hacking tools and scripts without fully understanding the technology or coding involved.	An example of a script kiddie is when an individual uses pre-existing tools to launch a website's DDos attack, resulting in a crash.
Secure Access Secure Edge (SASE)	SASE is a cloud-based architecture model that improves network security and application performance.	Secure web gateways, firewalls as a service, and software-defined wide area networks (SD-WAN) are examples of SASE services.
Sender Policy Framework (SPF)	SPF is an email validation technique that enables the receiving mail server to verify whether the sending mail server is authorized to send emails on behalf of a specific domain.	An example of SPF is when a company publishes SPF records in their DNS settings to designate which servers are authorized to send emails on their behalf.

Term	Definition	Example
Single Sign-On (SSO)	SSO is an access control method enabling users to log in once with a single set of credentials and access multiple systems or applications.	An example of SSO is when a user logs into their company's network using their employee ID and password and is then automatically granted access to various internal applications without entering their login credentials again.
Software-Defined Networking (SDN)	SDN is a software-controlled network architecture approach driven by application programming interfaces (APIs).	Examples of SDN applications include virtualized network functions, network slicing for 5G networks, and dynamic bandwidth allocation.
Strategic threat intelligence	Strategic threat intelligence focuses on identifying and addressing long-term, high-level threats and risks that could impact an organization's strategic goals.	An example of strategic threat intelligence is when an organization thoroughly analyzes potential risks and vulnerabilities to its operations to develop a long-term security strategy.
Tactical threat intelligence	Intelligence focused on specific, immediate threats and the tactics used by adversaries to inform defense and response strategies.	An example of tactical threat intelligence is when a security team analyzes recent cyber-attacks on similar organizations to identify potential vulnerabilities and adjust their defenses accordingly.
Technical threat intelligence	Intelligence related to the specific technical details of threats, including the tools, techniques, and procedures employed by attackers.	An example of technical threat intelligence is when an organization analyzes malware samples or network traffic from a recent attack to identify indicators of compromise and strengthen its defense capabilities.
Threat actor	A threat actor is an individual or group responsible for launching cyber attacks.	An example of a threat actor is a hacker who attempts to infiltrate a company's network to steal sensitive data for personal gain or to disrupt business operations.
Threat hunting	Proactive threat identification within an organization's network utilizes advanced techniques to detect and mitigate security incidents before they can cause damage.	An example of threat hunting is when a security team actively uses analytics and machine learning to monitor their network for suspicious activity.
Threat intelligence	Threat intelligence helps organizations understand and defend against potential security risks and attacks.	In practice, an example of threat intelligence is when a company uses real-time monitoring and analysis of network traffic and system logs to detect and prevent potential threats.
Threat intelligence gathering	Collecting and analyzing information about potential threats to enhance security posture and improve response strategies.	An example of threat intelligence gathering is when a security team leverages various sources, such as open-source and technical intelligence, to monitor for potential cyber-attacks against their organization.
User behavior analysis	UBA is a security approach that employs machine learning and analytics to identify behavior patterns and detect anomalies in user activity.	An example of UBA is when an organization uses software to monitor employee network activity and flag unusual behavior, such as accessing sensitive information outside of regular work hours or from an unfamiliar location.

Domain 2: Vulnerability Management

Term	Definition	Example
Active scanning	The process of actively probing and engaging with systems to uncover vulnerabilities.	A penetration tester uses active scanning techniques to identify exploitable weaknesses within a target network.
Adversary emulation	Simulating the tactics and techniques of real-world attackers to evaluate security measures.	An organization performs adversary emulation to test its defenses against techniques used by known cybercriminal groups.
Agent scanning	A vulnerability assessment technique that uses installed agents on systems to gather security data.	For instance, a security tool installed on each device allows for continuous monitoring and reporting of vulnerabilities.
Agentless scanning	Scanning is performed without requiring agents to be installed on target systems.	A company uses agentless scanning to evaluate cloud services where installing agents is not feasible.
Attack surface management	The continuous process of identifying and reducing a system's attack surface.	A security team actively manages its attack surface by regularly updating software and removing unused services.
Authentication	The process of verifying the identity of a user or system.	A website requires authentication through a username and password before granting access to user accounts.
Broken access control	A security flaw that permits unauthorized users to access restricted resources.	For example, a web application with broken access control may allow users to view other users' private data.
Bug bounty	A program that rewards individuals for finding and reporting bugs or vulnerabilities in software.	A tech company runs a bug bounty program to encourage ethical hackers to discover and report application security flaws.
Compensating control	Alternative measures mitigate risk when primary controls cannot be implemented.	For instance, if an organization can't implement strong encryption, they may use secure access controls as a compensating control.

Term	Definition	Example
Credentialed scanning	Scanning that utilizes valid user credentials to gain deeper access to system vulnerabilities.	For example, security teams conduct credentialed scans to validate user permissions and detect misconfigurations.
Cross-site forgery	An attack that tricks a user into executing unwanted actions on a website where they're authenticated.	An attacker could exploit cross-site request forgery to trick a user into unknowingly transferring funds from their bank account.
Cross-site scripting	A vulnerability that enables attackers to inject malicious scripts into web pages accessed by other users.	For instance, an attacker uses cross-site scripting to inject a malicious script that steals session cookies from unsuspecting users.
Cryptographic failures	Vulnerabilities in the algorithms or implementations of cryptographic systems.	An example of cryptographic failure is using outdated encryption methods that can be easily cracked.
Data poisoning	The act of injecting false or misleading data into a machine learning model to manipulate its output.	An attacker could poison a model by submitting false training data to manipulate its predictions.
Directory traversal	A security vulnerability that allows attackers to access files and directories outside the intended directory.	An attacker leverages directory traversal to access sensitive files on a server by manipulating file paths.
Dynamic scanning	Testing a running application to identify vulnerabilities during execution.	A QA team performs dynamic scans to evaluate web applications while they are live and running.
Edge discovery	Identifying and mapping all devices connected to the network edge.	Companies conduct edge discoveries to understand the devices on their network perimeter.
External network pen test	A test that simulates external hackers attempting to breach the network from outside by targeting servers, routers, websites, and employee computers.	A company hires a security firm to conduct an external network pen test to identify vulnerabilities accessible from the internet.
External scanning	The process of evaluating a system's external components for potential threats.	An organization conducts external scans to identify open ports that attackers could exploit.
Governance	The framework for how an organization manages its security and compliance responsibilities.	Effective governance ensures that security policies are enforced and aligned with business objectives.
Industrial Control Systems (ICS)	Industrial control systems (ICS) monitor and control physical processes in industries.	A manufacturing plant employs ICS to manage machinery and ensure efficient production.
Injection flaw	A vulnerability arises when untrusted data is sent to an interpreter as part of a command or query, potentially allowing attackers to execute unauthorized commands or access sensitive data.	SQL injection is a common vulnerability where an attacker alters a database query by injecting malicious SQL code.
Input validation	The process of verifying that input data is accurate and safe before processing.	Developers use input validation to prevent SQL injection attacks by sanitizing user input.
Internal scanning	A method for analyzing a system's internal components to identify vulnerabilities.	For example, a company conducts internal scans to detect security weaknesses within its network.
Local File Inclusion (LFI)	A vulnerability that enables an attacker to include files on a server via a web browser.	An attacker exploits LFI to access sensitive configuration files stored on the server.
Non-credentialed scanning	Scanning conducted without valid credentials to detect visible vulnerabilities.	An organization may conduct non-credentialed scans to identify vulnerabilities an external attacker could exploit without internal access.
Operational Technology (OT)	Hardware and software that detects or causes changes through direct monitoring and control of physical devices.	For example, an oil refinery uses OT systems to monitor and control its production processes.
Output coding	The practice of encoding output data to prevent injection attacks, like cross-site scripting.	A web application uses output coding to display user-generated content safely without executing scripts.
Overflow vulnerabilities	Exploits occur when a program writes more data to a buffer than it can handle, leading to unexpected behavior.	A buffer overflow vulnerability enables an attacker to overwrite critical memory and execute arbitrary code.
Parameterized queries	A method to execute database queries securely by separating SQL code from data inputs.	Developers use parameterized queries to prevent SQL injection by ensuring user input is treated as data rather than executable code.
Passive discovery	A method of collecting information about a target system without direct interaction, reducing the risk of detection.	Network administrators use passive discovery to monitor traffic patterns and identify new devices without disruption.
Passive scanning	Monitoring network traffic without actively scanning systems for vulnerabilities.	For example, a security team monitors network packets to detect unauthorized devices without triggering an alert.
Penetration testing	The practice of testing a computer system, network, or web application to find vulnerabilities that an attacker could exploit.	Security teams perform penetration testing to uncover vulnerabilities before malicious actors can exploit them.
Policies	Formal guidelines that dictate how security measures and procedures should be implemented.	An organization establishes data privacy policies that govern employee access to sensitive information.

Term	Definition	Example
Privilege escalation	A technique where attackers gain higher-level permissions within a system, allowing them to access more sensitive data.	An attacker could escalate privileges to gain access to sensitive admin functions they are not authorized to reach.
Remote code execution	A vulnerability that enables an attacker to execute arbitrary code on a remote machine.	An example of remote code execution is when an attacker exploits a web application vulnerability to execute malicious scripts on the server.
Remote File Inclusion (RFI)	A vulnerability that allows an attacker to include a file from a remote server in a web application.	An example of RFI is when an attacker alters a URL to include malicious scripts from an external server.
Secure Software Development Life Cycle (SDLC)	A framework that integrates security practices into the software development process.	A company adopts a secure SDLC to ensure that security is considered at every stage of software development.
Security controls	Measures implemented by security teams to safeguard networks from cyber threats, with findings typically informing penetration testing efforts.	An organization uses a range of security controls to protect its network, such as firewalls and intrusion detection systems.
Server-side request forgery	An attack that enables an attacker to send unauthorized requests from a vulnerable server.	In an SSRF attack, an attacker can trick a server into requesting sensitive internal services.
Service-Level Objectives (SLOs)	Specific, measurable goals related to the service provided by IT, typically focusing on performance and availability.	An IT department establishes SLOs to ensure 99.9% system uptime for critical applications.
Session management	The process of managing user sessions securely, including authentication and session expiration.	An online service uses session management techniques to log users out after a period of inactivity automatically.
Static scanning	Analyzing source code without executing the program to find vulnerabilities.	Developers run static scans on their codebase to catch security issues before deployment.
Supervisory Control and Data Acquisition (SCADA)	A type of ICS that gathers and analyzes real-time data for process control.	Utilities often use SCADA systems to monitor and manage their electricity distribution networks.
Threat modeling	Identifying and evaluating potential security threats to a system, application, or network and prioritizing mitigation efforts based on the likelihood and impact of each threat.	Security teams use threat modeling to assess the risks of a new application before deployment.
Zero-day	A previously unknown vulnerability that attackers can exploit before developers have the opportunity to address it.	An attacker exploits a zero-day vulnerability in widely used software, compromising millions of systems before a patch is released.

Domain 3: Incident Response and Management

Term	Definition	Example
Business Continuity (BC)	Business continuity involves planning to maintain essential functions during and after a disaster.	A business continuity plan may outline steps to maintain customer service during a prolonged IT outage.
Chain of custody	The chain of custody refers to the documentation of evidence from its acquisition until its presentation in court.	In digital forensics, maintaining a transparent chain of custody is critical to ensure the integrity of electronic evidence.
Cyber kill chain	A model outlining the stages of a cyberattack, from initial reconnaissance to the final objective, is used to understand and mitigate attack strategies.	The cyber kill chain helps organizations identify and mitigate threats at each stage of an attack, from surveillance to exfiltration.
Diamond model of intrusion analysis	The diamond model is a framework for describing and analyzing cyber intrusions.	Analysts use the diamond model to examine each aspect of a cyber breach, including the adversary, capability, infrastructure, and victim.
Disaster Recovery (DR)	Disaster recovery focuses on restoring systems and data after a catastrophic event.	Disaster recovery plans often involve data backups and redundant systems to facilitate quick recovery.
Forensic investigation	Examining and analyzing digital evidence to investigate and understand security incidents or breaches.	Digital forensic investigators extract data from compromised devices to determine the cause of a cyber incident.
Incident response	The structured approach to managing and responding to security incidents, including detection, containment, eradication, and recovery.	A well-coordinated response strategy can significantly minimize the impact of a cyber incident.
Incident response plan	Protocols for managing incidents during penetration testing, including containment, mitigation, and notification procedures.	An organization's incident response plan outlines step-by-step procedures to respond to data breaches effectively.
Indicators of Compromise (IoC)	Indicators of Compromise (IoC) are pieces of evidence that suggest a computer system may have been compromised.	Unusual network traffic and unauthorized file changes may indicate a security breach during an investigation.

Term	Definition	Example
MITRE ATT&CK	MITRE developed a framework for describing and analyzing the actions and techniques used by adversaries during cyberattacks based on observed behaviors.	Security teams use MITRE ATT&CK to map observed adversary behaviors and improve their threat detection capabilities.
Open-Source Security Testing Methodology Manual (OSS TMM)	OSS TMM is a set of guidelines for conducting thorough security testing.	The OSS TMM offers testers a structured approach to identifying vulnerabilities in software and systems.
Open Web Application Security Project (OWASP)	An open community focused on enhancing software security, offering resources to improve security practices.	Developers commonly refer to the OWASP Top Ten to identify and address the most critical web application security risks.
Playbooks	Playbooks are detailed guides that outline specific actions to respond to threats or incidents.	Cybersecurity teams use playbooks to streamline decision-making during a cyber-attack.
Root cause analysis	Root cause analysis is a technique used to identify the underlying cause of a problem or incident.	After a network breach, conducting a root cause analysis helps organizations identify the vulnerabilities that were exploited.
Tabletop exercise	A tabletop exercise is a training simulation that recreates emergency scenarios to evaluate and enhance response strategies.	Organizations conduct tabletop exercises to prepare their staff for potential cyberattacks by testing their response plans in simulated scenarios.

Domain 4: Reporting and Communication

Term	Definition	Example
Business process interruption	An unplanned disruption that interrupts or delays the operations of an organization.	The earthquake led to a major disruption in business operations, impacting production schedules.
Compensating controls	When primary controls prove ineffective, alternative measures are put in place to mitigate risk.	When the primary security system failed, compensating controls were implemented to maintain data protection.
Compliance reports	Documentation that demonstrates compliance with regulatory requirements and internal policies.	An annual compliance report was submitted to showcase the company's adherence to industry standards.
Degrading functionality	A decline in system performance that impairs usability or efficiency.	As the software aged, users started encountering declining functionality, affecting workflow efficiency.
Key Performance Indicators (KPIs)	Metrics assess an organization's performance in achieving its objectives or specific activities.	The sales department established key performance indicators to monitor progress toward its quarterly revenue targets.
Legacy systems	Older technology systems that are still in use but may need to integrate better with newer applications.	The organization faced compatibility challenges when trying to integrate its legacy systems with the latest software.
Memorandum of Understanding (MOU)	A formal agreement between parties establishes a clear course of action or mutual understanding.	The MOU outlined the collaboration between the two organizations without creating a legally binding commitment.
Organizational governance	The set of rules and practices that guide an organization in maintaining accountability, fairness, and transparency.	The company's organizational governance policies were reviewed annually to ensure compliance and assess their effectiveness.
Patching	The process of updating software to address vulnerabilities and enhance performance.	The IT department implemented a regular patching schedule to safeguard against security breaches.
Proprietary systems	Proprietary systems are developed and owned by a specific company, typically with limitations on usage and compatibility.	Organizations must purchase licenses directly from the vendor to use proprietary systems to receive ongoing support and updates.
Service-Level Agreement (SLA)	A contract outlines the agreed-upon service levels between a provider and a customer.	The SLA defined the guaranteed response time for technical support services.

Next steps

Refer to this comprehensive list of terms, definitions, and examples in conjunction with practice exam questions and other study materials. Also consider finding a study companion who can quiz you on this information as you prepare for your exam.

You've got this!

Author(s)

[DeeDee Collette](#)



Skills Network